

# Seguridad en Redes



Ing. Gabriel Filippa

Ing. Joaquín Nepotti



# Contenido

- Seguridad en la comunicación
- Tipos de ataques – tipos de atacantes
- Firewall
- Configuraciones de firewalls
- IDS

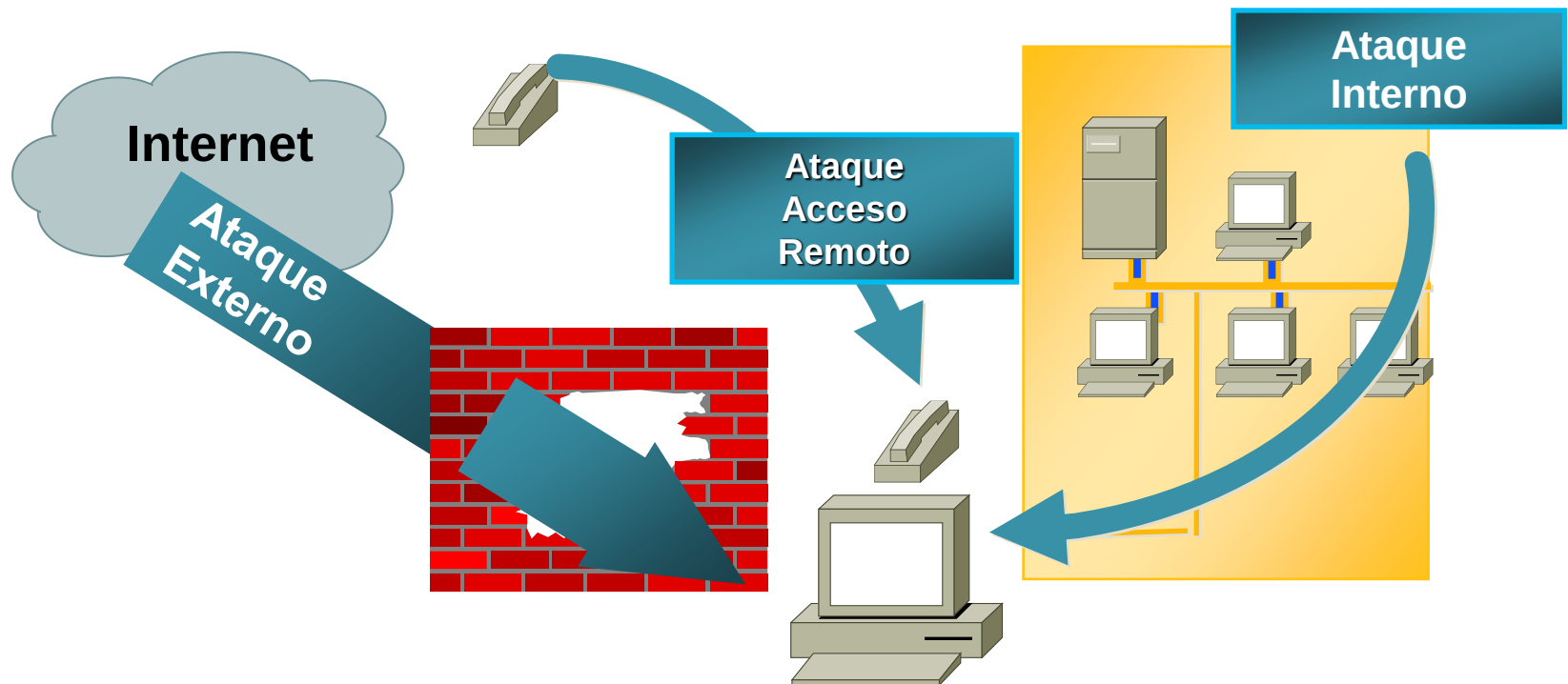
# Seguridad en la comunicación

Políticas y prácticas adoptadas para prevenir y supervisar el acceso no autorizado, el uso indebido, la modificación o la denegación de una red informática y sus recursos accesibles.



# Tipos de ataques

- Externos
  - Intencionados
  - No intencionados



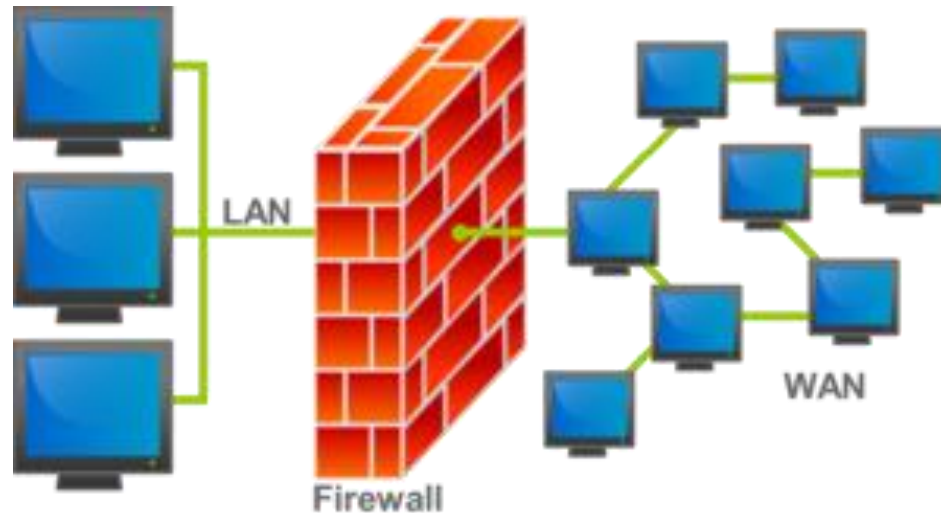
# Seguridad externa

- Nos enfocamos en la seguridad externa:
  - Firewalls
  - Proxys
  - NAT/PAT
  - Control de accesos
  - Cifrado

# Tipos de atacantes

- **Hacker:** tiene un conocimiento profundo de un área y aprovecha este conocimiento a su favor o en favor de otros.
- **White Hat:** hackers éticos. Son aquellos hackers que utilizan sus conocimientos para encontrar vulnerabilidades en un sistema informático, y lo ponen en conocimiento de las compañías desarrolladoras o empresas, con el objetivo de poder estudiar y corregir los fallos
- **Black Hat:** criminales causantes de los ciberataques que utiliza todo su conocimiento para introducirse en los sistemas como los hackers blancos pero de una manera maliciosa, buscando su beneficio personal/económico.
- **Grey Hat:** hackers que rompen los niveles de seguridad de los sistemas de una empresa para, posteriormente, ofrecer sus servicios para mejorar dicha seguridad.

# Firewalls o cortafuego



- Dispositivo formado por uno o varios equipos que se sitúan entre la red de la empresa y la red exterior (*normalmente Internet*), que **analiza todos los paquetes que transitan entre ambas redes y filtra** los que no deben ser reenviados, de acuerdo con un **criterio establecido de antemano**

# Firewall: características

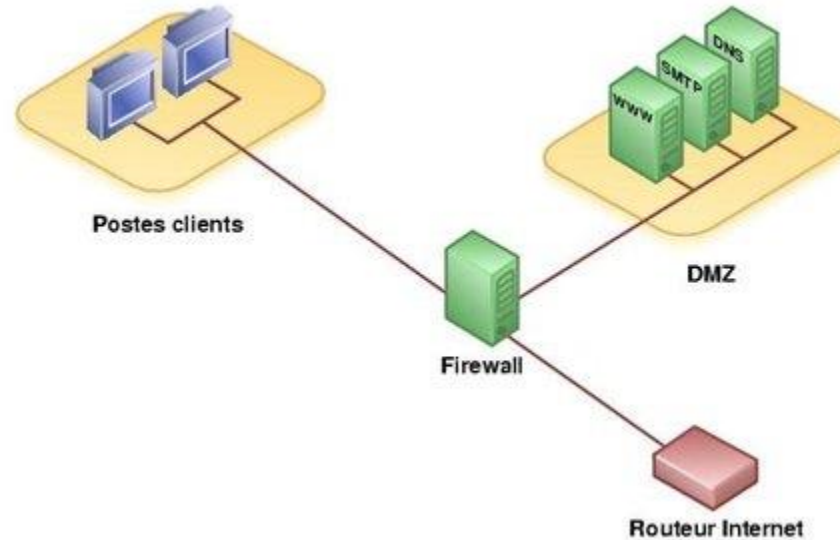
Crea un perímetro de defensa y seguridad alrededor de la red a proteger.

Para que no se convierta en cuello de botella en la red, deben de procesar los paquetes a una **velocidad** igual o superior al router.

Se debe configurar de acuerdo a los servicios que brinde la red, así como conexiones entrantes a la red.



# Firewall: características



El firewall realiza filtrado de paquetes:

- A nivel de red: direcciones IP
- A nivel de transporte: puertos y tipo de accesos.
- A nivel de aplicación: datos a través de pasarelas para las aplicaciones permitidas analizando el contenido de los paquetes y los protocolos de aplicación (ejemplo servidor proxy).

**Violan el esquema de modelo de capas**

# Algunas configuraciones de firewalls

## *Screened Host Firewall*

- un router separando la red Intranet de Internet, que puede enviar el tráfico de entrada sólo al *host bastión*.

## *Dual Homed Gateway*

- un host bastión o pasarela para las aplicaciones permitidas separando la red Intranet de Internet

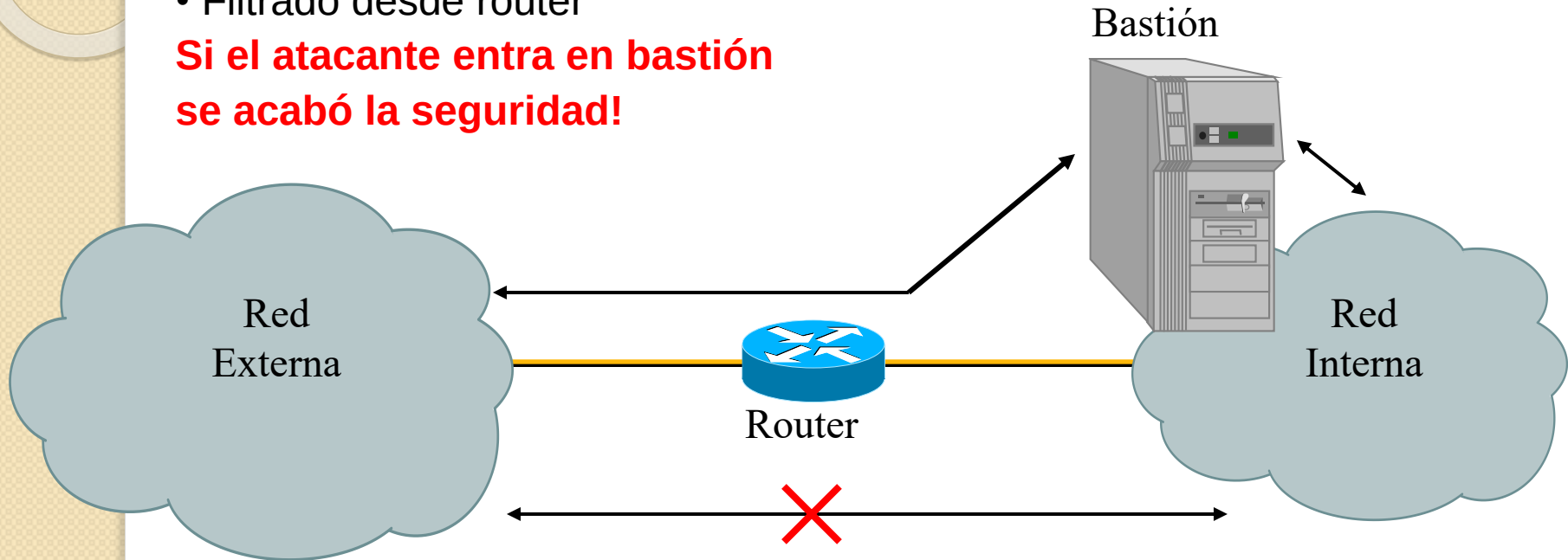
## *Screened Subnet(DMZ)*

- con dos routers separando la red Intranet e Internet y con el host bastión dentro de la red formada por ambos routers. La red interna es conocida como zona neutra de seguridad o zona desmilitarizada.

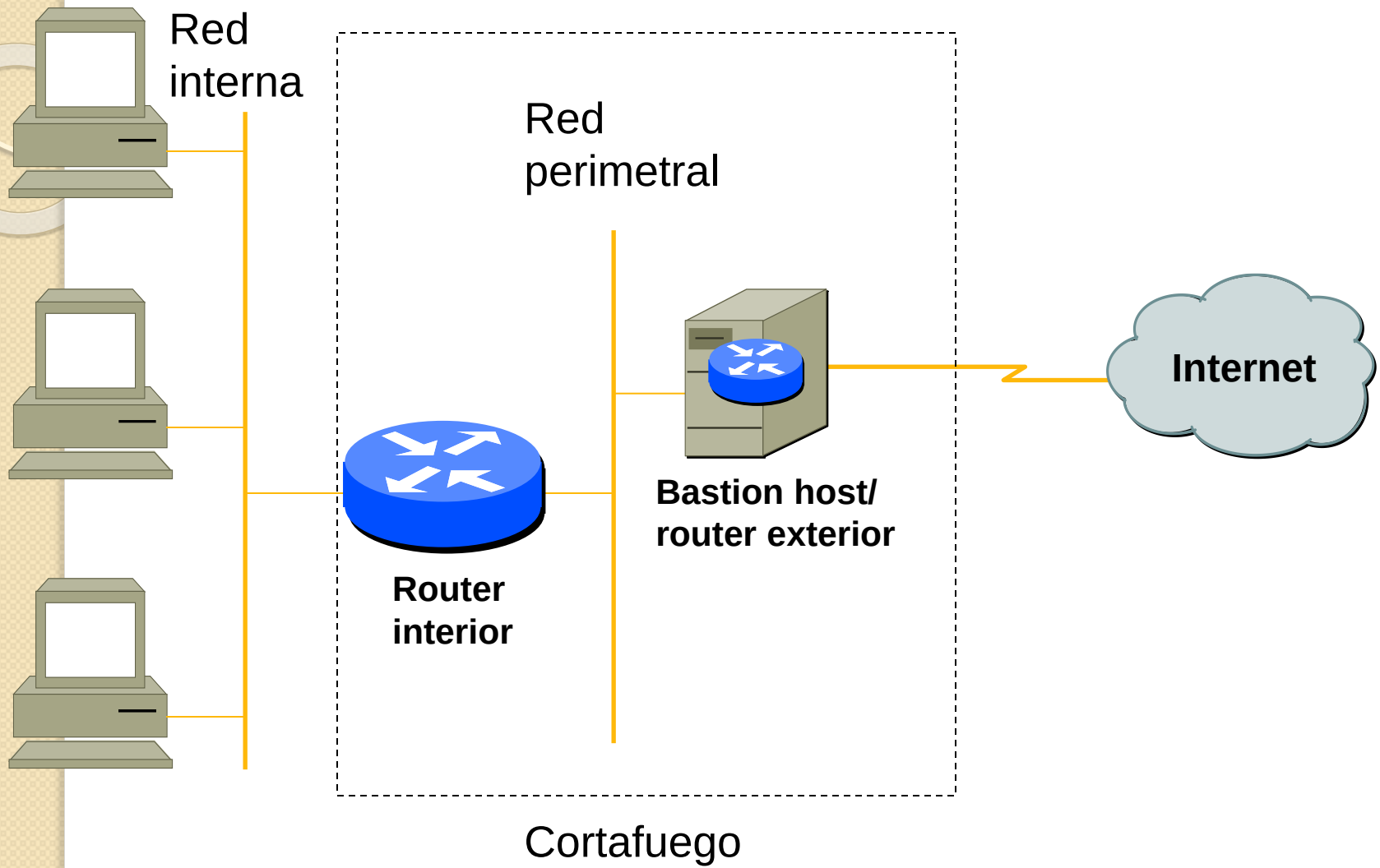
# Screened host

- Router bloquea todo el tráfico hacia la red interna, excepto al bastión
- Servicios vía proxy desde el bastión
- Filtrado desde router

**Si el atacante entra en bastión  
se acabó la seguridad!**



**Esta arquitectura permite mantener la conectividad transparente cuando esté justificado, obligando a pasar por el 'bastion host' el resto**



# Dual-homed gateway

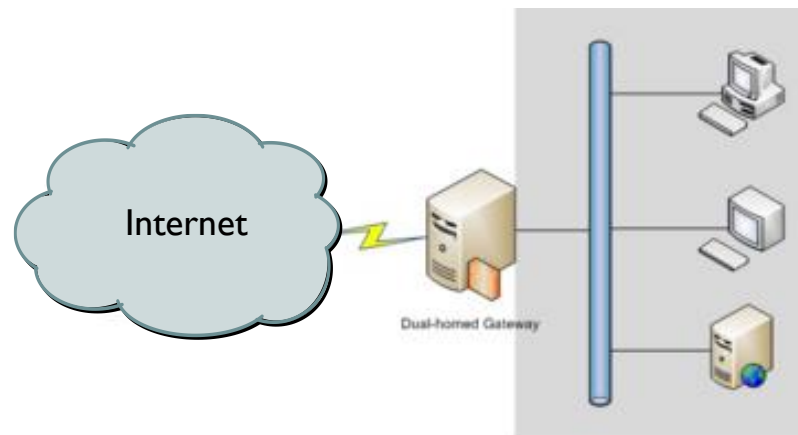
Un host (*bastión*) con dos tarjetas de red, conectadas a redes diferentes

En esta configuración, el **bastión puede filtrar hasta capa de aplicación.**

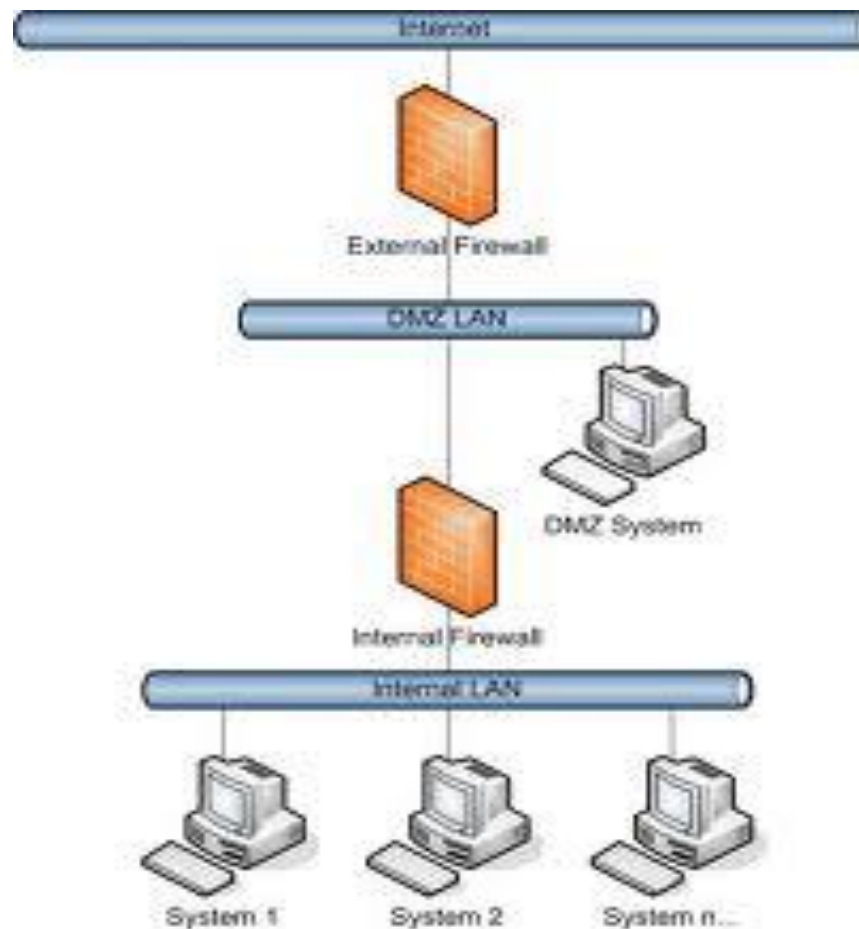
Son sistemas muy baratos y fáciles de implementar

Sólo soportan servicios mediante proxy

El filtrado de paquetes, puede realizarse en *Linux* a través de “*iptables*”



# Screened subnet



# Screened subnet

Se sitúa una red DMZ (*DeMilitarized Zone*) entre la interna y la externa, usando dos routers y que contiene el bastión

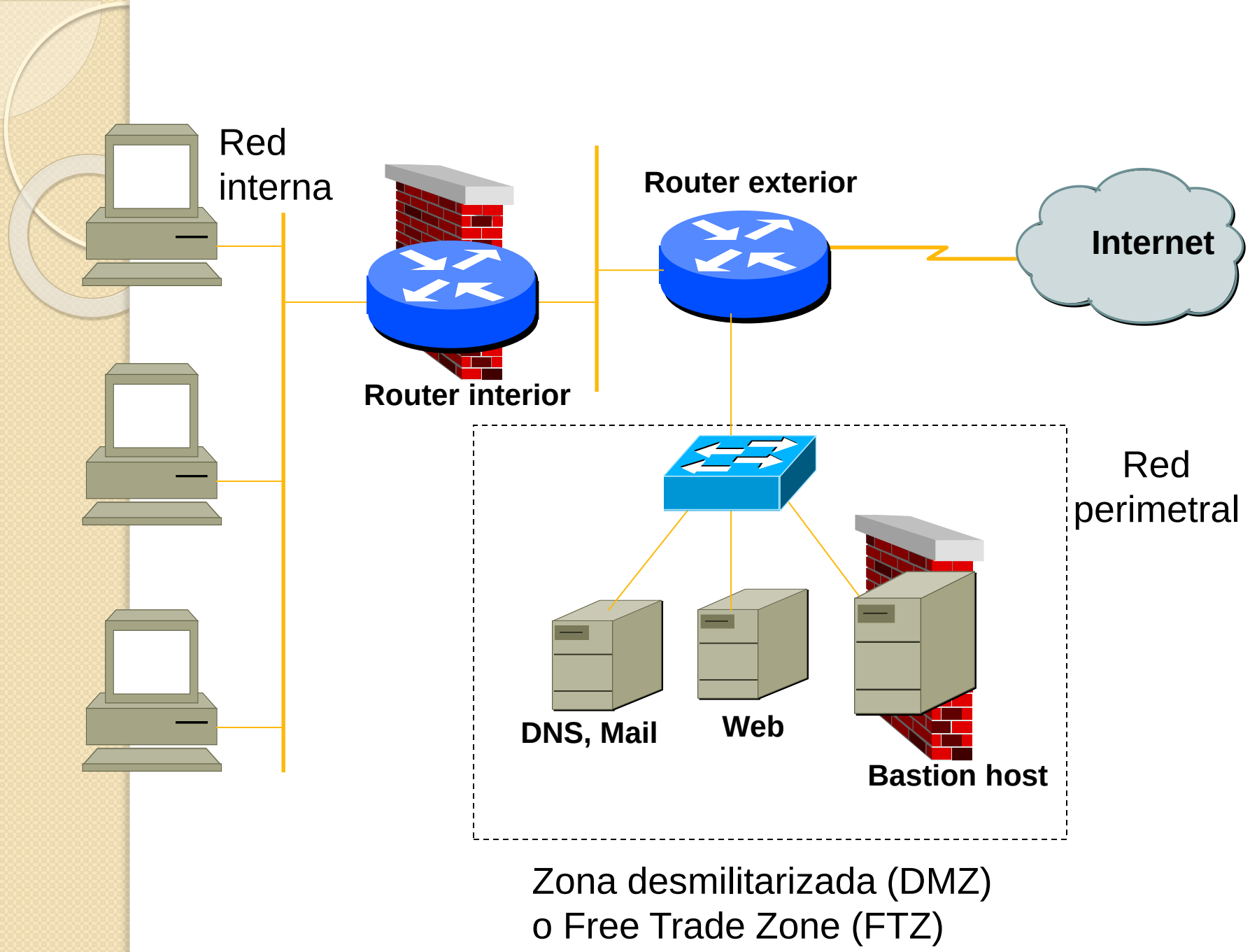
Tráfico sospechoso se envía hacia el bastión, si no puede pasar directamente.

Soporta servicios mediante proxy (bastión)

Soporta filtrado de paquetes (routers)

Implementación costosa

Si el atacante entra en el bastión, todavía tiene un router por delante (no puede hacer sniffing)





# Preparación del router

- Definir la *access list* para redirigir el tráfico externo al bastión
- Rechazar los mensajes externos con dirección interna (*anti-spoofing*)
- Deshabilitar la respuesta a los mensajes “*ICMP redirect*”
- Quitar el soporte de acceso por telnet (*al menos externamente*) y WEB.
- Separar tráfico de gestión y de servicio, mediante asignación de diferentes direcciones, o diferente localización

# Detección de intrusos: IDS

En muchas ocasiones, el atacante **enmascara** el ataque en tráfico permitido por el *cortafuegos* y por tanto para delatarlo se necesita un **IDS**.

Son complementarios a los Firewalls.

Características deseables:

- Ejecución continua y autoanálisis
- Utilización de mínimos recursos posibles
- Adaptación a los cambios de sistemas y usuarios:  
***aprender por su experiencia y configurarse.***

# Tipos de IDS

- **NIDS:** (*NetworkIDS*): un IDS basado en red, detectando ataques a todo el segmento de la red. Su interfaz debe funcionar en modo promiscuo capturando así todo el tráfico de la red.
- **HIDS:** (*HostIDS*): el principio de funcionamiento de un HIDS, depende del éxito de los intrusos, que generalmente dejen rastros de sus actividades en el equipo atacado, cuando intentan adueñarse del mismo, con propósito de llevar a cabo otras actividades. El HIDS intenta detectar tales modificaciones en el equipo afectado, y hacer un reporte de sus conclusiones.

# Sistemas pasivos y sistemas reactivos

- En un sistema pasivo, el sensor detecta una posible intrusión, almacena la información y manda una señal de alerta que se almacena en una base de datos.
- En un sistema reactivo, el IDS responde a la actividad sospechosa reprogramando el cortafuegos para que bloquee tráfico que proviene de la red del atacante. Un sistema que reacciona ante el ataque previniendo que este continúe, se denomina IPS por sus siglas en ingles de "Intrusion prevention system".

# IDS Ejemplos

- SNORT - <https://www.snort.org/>



- SURICATA - <https://suricata-ids.org/>



# Jarrón de miel (*HONEY POT*)

En ocasiones es interesante aprender de los propios atacantes.

Para ello, en las redes se ubican **servidores** puestos adrede para que los intrusos los saboteen y son monitorizados por sistemas que actúan como **puentes** a los servidores, registrando de forma transparente los paquetes que acceden a dichos servidores.

Detectado un ataque (*por modificación de la estructura de archivos*), se recompone la traza del atacante (*secuencia de paquetes registrados en el monitor puente*) y se pasa a un **análisis forense**.

Este análisis forense concluye, en caso de detectar un nuevo ataque, en **una nueva regla de detección**.